

# Contents

|       |                        |   |
|-------|------------------------|---|
| 1     | DD09: 認可ヘルパ            | 1 |
| 1.1   | 0. 文書情報                | 1 |
| 1.2   | 1. 対象範囲                | 1 |
| 1.3   | 2. 収録ロジック・対応章          | 1 |
| 1.4   | 3. 詳細設計本文              | 1 |
| 1.4.1 | 3.1 認可ヘルパ実装            | 1 |
| 1.4.2 | 3.2 Principal 構築（参照のみ） | 2 |
| 1.4.3 | 3.3 オーナー境界（NFR-301）    | 3 |
| 1.4.4 | 3.4 不正アクセスの監査記録        | 3 |
| 1.5   | 4. 関連設計                | 3 |
| 1.6   | 5. テスト観点               | 3 |
| 1.6.1 | 5.1 オーナー境界によるデータ分離検証   | 3 |
| 1.6.2 | 5.2 その他観点              | 3 |
| 1.7   | 6. 未確定事項・確認事項          | 4 |

## 1 DD09: 認可ヘルパ

### 1.1 0. 文書情報

| 項目      | 内容                                        |
|---------|-------------------------------------------|
| 文書名     | DD09: 認可ヘルパ                               |
| 詳細設計 ID | DD09                                      |
| 対象システム  | FAQ AI ウィジェット SaaS / メインシステム              |
| 関連機能 ID | NFR-301（オーナー境界によるデータ分離） / FR-007 / AC-017 |
| 作成日     | 2026-05-17                                |
| 版数      | v1.0                                      |
| ステータス   | 承認済                                       |

### 1.2 1. 対象範囲

| 種別    | ID                                    | 名称                                                                 |
|-------|---------------------------------------|--------------------------------------------------------------------|
| 機能    | NFR-301                               | オーナー境界によるデータ分離                                                     |
| 機能    | FR-007                                | 認証セッション + 認可                                                       |
| ライブラリ | app/workers/main-api/src/lib/authz.ts | requireTenant / requireProjectRole / requireInquiry / requireOwner |

### 1.3 2. 収録ロジック・対応章

| 元章     | 元タイトル | 概要                                                                 |
|--------|-------|--------------------------------------------------------------------|
| § 10.6 | 認可ヘルパ | requireTenant / requireProjectRole / requireInquiry / requireOwner |

### 1.4 3. 詳細設計本文

#### 1.4.1 3.1 認可ヘルパ実装

```
// app/workers/main-api/src/lib/authz.ts
export type ProjectRole = 'admin' | 'member';

export function requireTenant(c: Context, expectedTenantId: string) {
  const principal = c.get('principal');
  if (principal.contractOwnerUserId !== expectedTenantId) throw new HTTPException(404); // 404
}

export function requireOwner(c: Context) {
```

```

const principal = c.get('principal');
if (!principal.isOwner) throw new HTTPException(403); // E-AUTHZ-OWNER-ONLY
}

export async function requireProjectRole(c: Context, projectId: string, minRole: ProjectRole) {
  const principal = c.get('principal');
  const project = await c.env.DB.prepare(
    `SELECT contract_owner_user_id FROM projects WHERE id = ?1`
  ).bind(projectId).first<{ contract_owner_user_id: string }>();
  if (!project) throw new HTTPException(404);
  if (project.contract_owner_user_id !== principal.contractOwnerUserId) throw new HTTPException(403);
  if (principal.isOwner) return; // オーナーは全プロジェクト bypass(暗黙の admin)

  const granted = principal.projectRoles.get(projectId);
  if (!granted) throw new HTTPException(404); // E-AUTHZ-PROJECT-DENIED(404 偽装)
  if (minRole === 'admin' && granted !== 'admin') throw new HTTPException(403); // E-AUTHZ-FORBIDDEN
  // minRole='member' は admin/member いずれでも通過
}

export async function requireInquiry(c: Context, inquiryId: string) {
  const principal = c.get('principal');
  const row = await c.env.DB.prepare(
    `SELECT contract_owner_user_id, project_id FROM inquiries WHERE id = ?1`
  ).bind(inquiryId).first<{ contract_owner_user_id: string; project_id: string }>();
  if (!row) throw new HTTPException(404);
  if (row.contract_owner_user_id !== principal.contractOwnerUserId) throw new HTTPException(403);
  await requireProjectRole(c, row.project_id, 'member');
}

export function requireRole(...roles: Role[]): MiddlewareHandler {
  return async (c, next) => {
    const principal = c.get('principal');
    if (!roles.includes(principal.role)) throw new HTTPException(403);
    await next();
  };
}

```

#### 1.4.2 3.2 Principal 構築 (参照のみ)

`c.get('principal')` で取得する Principal の構築フローは [../02\\_基本設計/08\\_認証・認可設計.md §6.1](#) を正本とする。Principal には以下を含む。

- `userId`: ユーザー ID(オーナー / プロジェクト管理者 / メンバー全員)
- `contractOwnerUserId`: 所属契約の owner user\_id(本人がオーナーなら自身の userId、メンバーなら所属契約の owner user\_id)
- `actorRole`: 操作者種別(管理者 = `users` 行 / エンドユーザー = `end_users` 行 / 運営者 = 別 D1)。Principal 構築時に決定され、`audit_logs.actor_role` の値 (`admin` / `end_user` / `service_operator` / `system`) に対応
- `isOwner`: オーナー判定(`contract_owners` 行存在で判定 = `co.user_id IS NOT NULL`)
- `projectRoles`: `Map<projectId, 'admin' | 'member'>`。オーナー / メンバー共通で `project_users WHERE valid=1` を 1 クエリで取得して構築する。認可ヘルパは `isOwner=true` のときに `projectRoles` の中身を参照せず `bypass` する優先順位を保つ。`projectRoles` は通知宛先解決と画面表示の事実情報として参照可能

##### 1.4.2.1 Principal 構築クエリ (参考、基本設計と同期)

```

SELECT u.id, u.role, u.status, u.valid,
       (co.user_id IS NOT NULL) AS is_owner,
       COALESCE(co.user_id, pu.contract_owner_user_id) AS contract_owner_user_id
FROM users u
LEFT JOIN contract_owners co ON co.user_id = u.id AND co.valid = 1

```

```
LEFT JOIN project_users pu ON pu.user_id = u.id AND pu.valid = 1
WHERE u.id = ?1 AND u.valid = 1
LIMIT 1;
```

projectRoles は別途 SELECT project\_id, role FROM project\_users WHERE user\_id=? AND valid=1 で取得する。

### 1.4.3 3.3 オーナー境界 (NFR-301)

すべての CRUD API は **contract\_owner\_user\_id** フィルタを必須とする。requireTenant/requireProject/requireInquiry で境界チェックを実施し、他オーナーのデータには 404 を返す（漏洩防止のため 403 ではなく 404）。

### 1.4.4 3.4 不正アクセスの監査記録

境界違反検知時は authz.owner\_boundary\_violation/authz.project\_boundary\_violation を retention\_class=general で記録する。詳細は [DD10\\_監査ログ書込・完全性検証.md](#) を参照。

## 1.5 4. 関連設計

| 種別      | 参照先                                                                 |
|---------|---------------------------------------------------------------------|
| 要件      | ../01_要件定義/index.md                                                 |
| 基本設計    | ../02_基本設計/index.md                                                 |
| 権限設計    | ../02_基本設計/04_権限設計.md                                               |
| 認証・認可設計 | ../02_基本設計/08_認証・認可設計.md                                            |
| 運用設計    | ../04_運用設計/index.md                                                 |
| 将来対応    | ../05_future/index.md                                               |
| 関連 DD   | DD01_アカウント・ユーザー管理.md / DD02_プロジェクト・FAQ 管理.md / DD10_監査ログ書込・完全性検証.md |

## 1.6 5. テスト観点

| AC ID  | テスト ID              | テスト方式     | テストファイル                                             |
|--------|---------------------|-----------|-----------------------------------------------------|
| AC-017 | iso-cross-owner-001 | Isolation | workers/main-api/test/isolation/cross-owner.test.ts |

### 1.6.1 5.1 オーナー境界によるデータ分離検証

```
// tests/isolation/cross-owner.test.ts
describe('クロス契約アクセス試行', () => {
  it('他契約の inquiry にアクセスできない', async () => {
    const ownerA = await createOwnerAccount();
    const ownerB = await createOwnerAccount();
    const inquiryB = await createInquiry(ownerB);
    const sessionA = await loginAs(ownerA.adminEmail);
    const res = await fetch(`/api/v1/inquiries/${inquiryB.id}`, { headers: { Cookie: sessionA } })
    expect(res.status).toBe(404); // 漏洩しないために 403 ではなく 404
  });
  // 50 ケース x 月次 + 5 ケース x 年次手動
});
```

### 1.6.2 5.2 その他観点

| 観点 | 内容                                                                                                     |
|----|--------------------------------------------------------------------------------------------------------|
| 単体 | requireTenant/requireProject/requireInquiry/requireRole の各分岐                                           |
| 結合 | プロジェクト割当がない(project_users 行なし)メンバーによる FAQ 編集試行で 404 偽装(E-AUTHZ-PROJECT-DENIED)/ 該当 PJ の member+ なら 200 |

| 観点  | 内容                                                                                                             |
|-----|----------------------------------------------------------------------------------------------------------------|
| 異常系 | 削除済オーナー所属メンバーのアクセス時 401 + セッション失効                                                                              |
| 境界値 | アカウント削除はアカウントレベル論理削除のため、現存メンバーは常に 1 件以上の割当を保持。割当 0 件はテスト境界として「データ不整合時のフェイルセーフ動作」 (/auth/login への強制ログアウト) を検証する |
| 月次  | クロス契約侵入試行 50 ケース月次 + 5 ケース年次手動                                                                                 |

## 1.7 6. 未確定事項・確認事項

| 確認事項 ID | 確認内容                | 優先度 | ステータス |
|---------|---------------------|-----|-------|
| -       | v1.0 リリース時点で全項目確定済み | 低   | 確認済   |